

# Foundation of Computer Security (CSE345)

## Midsem Exam

Name: Utkarsh Arora

Roll No: 2020143

Q1)

a)

No of items purchased and price are not anonymised, because I have assumed them to be sensitive information.

K-Anonymity with  $K = 2$ :

| Customer ID | Name | Place    | City     | Country   | No item purchased | Price |
|-------------|------|----------|----------|-----------|-------------------|-------|
| C000**      | *    | *        | *        | *         | 2                 | 6000  |
| C000**      | *    | New York | New York | USA       | 2                 | 3000  |
| C000**      | *    | New York | New York | USA       | 3                 | 5000  |
| C000**      | *    | *        | *        | *         | 2                 | 5000  |
| C000**      | *    | *        | *        | *         | 1                 | 10000 |
| C000**      | *    | New York | New York | USA       | 3                 | 5000  |
| C000**      | *    | Brisban  | Brisban  | Australia | 2                 | 7000  |
| C000**      | *    | Brisban  | Brisban  | Australia | 1                 | 7000  |
| C000**      | *    | Chennai  | Chennai  | India     | 1                 | 8000  |
| C000**      | *    | Mumbai   | Mumbai   | India     | 1                 | 7000  |
| C000**      | *    | Chennai  | Chennai  | India     | 1                 | 7000  |
| C000**      | *    | Mumbai   | Mumbai   | India     | 2                 | 7000  |

K-Anonymity with  $K = 3$ :

| Customer ID | Name | Place    | City     | Country | No item purchased | Price |
|-------------|------|----------|----------|---------|-------------------|-------|
| C000**      | *    | *        | *        | *       | 2                 | 6000  |
| C000**      | *    | New York | New York | USA     | 2                 | 3000  |
| C000**      | *    | New York | New York | USA     | 3                 | 5000  |
| C000**      | *    | *        | *        | India   | 2                 | 5000  |
| C000**      | *    | *        | *        | *       | 1                 | 10000 |
| C000**      | *    | New York | New York | USA     | 3                 | 5000  |
| C000**      | *    | *        | *        | *       | 2                 | 7000  |
| C000**      | *    | *        | *        | *       | 1                 | 7000  |
| C000**      | *    | *        | *        | India   | 1                 | 8000  |
| C000**      | *    | *        | *        | India   | 1                 | 7000  |
| C000**      | *    | *        | *        | India   | 1                 | 7000  |
| C000**      | *    | *        | *        | India   | 2                 | 7000  |

b) To protect privacy, we anonymise the data.

However, in doing so, we have reduced the utility of the data. While anonymising the data, we can take steps to ensure the data is more usable.

- i. We can reduce the amount of suppression in the data. Suppression is the number of deleted entries. We can see that in 3-anonymous, we have deleted all the cities in India, while in 2-anonymous, we have not done that. Thus, the 2-anonymous data has higher utility.
- ii. We can instead increase Generalization. In 3-anonymisation, we have deleted the county cells for Australia, Canada and UK. We can instead generalise these as “Commonwealth Nations”. This would maintain 3-anonymity, while providing higher utility to the data.
- iii. We can generate synthetic. We can use the demographic information and sensitive

information, and create a new name, etc. This information has a lot of utility, since it represents an actual demographic, while still maintaining the privacy of the name of the original person. This data can also be sold without breach of privacy.

| Customer ID | Name | Place    | City     | Country               | No item purchased | Price |
|-------------|------|----------|----------|-----------------------|-------------------|-------|
| C000**      | *    | *        | *        | [CommonWealth Nation] | 2                 | 6000  |
| C000**      | *    | New York | New York | USA                   | 2                 | 3000  |
| C000**      | *    | New York | New York | USA                   | 3                 | 5000  |
| C000**      | *    | *        | *        | [CommonWealth Nation] | 2                 | 5000  |
| C000**      | *    | *        | *        | [CommonWealth Nation] | 1                 | 10000 |
| C000**      | *    | New York | New York | USA                   | 3                 | 5000  |
| C000**      | *    | Brisban  | Brisban  | Australia             | 2                 | 7000  |
| C000**      | *    | Brisban  | Brisban  | Australia             | 1                 | 7000  |
| C000**      | *    | Chennai  | Chennai  | India                 | 1                 | 8000  |
| C000**      | *    | Mumbai   | Mumbai   | India                 | 1                 | 7000  |
| C000**      | *    | Chennai  | Chennai  | India                 | 1                 | 7000  |
| C000**      | *    | Mumbai   | Mumbai   | India                 | 2                 | 7000  |

c) We have data from Alumni survey conducted in IIITD. We have the following data:

| Email Address                                                        | Review      |
|----------------------------------------------------------------------|-------------|
| <a href="mailto:raghav16228@iiitd.ac.in">raghav16228@iiitd.ac.in</a> | lorem ipsum |
| <a href="mailto:priya26@gmail.com">priya26@gmail.com</a>             | lorem ipsum |
| <a href="mailto:yaboi225@gmail.com">yaboi225@gmail.com</a>           | lorem ipsum |
| <a href="mailto:roshan16024@iiitd.ac.in">roshan16024@iiitd.ac.in</a> | lorem ipsum |
| <a href="mailto:qwerty123@yahoo.com">qwerty123@yahoo.com</a>         | lorem ipsum |
| <a href="mailto:asdfgh123@yahoo.com">asdfgh123@yahoo.com</a>         | lorem ipsum |
| <a href="mailto:zxcvbn123@yahoo.com">zxcvbn123@yahoo.com</a>         | lorem ipsum |
| <a href="mailto:suman16229@iiitd.ac.in">suman16229@iiitd.ac.in</a>   | lorem ipsum |

We have to protect the participant's privacy in line with GDPR requirements. I have chosen to make the data k-anonymous.

I have chosen k-anonymity because it follows the GDPR requirements. K-anonymity is a property of a dataset that indicates the re-identifiability of the records. By

using k-anonymity on this dataset, I can make sure the identifying information of the alumni is hidden; k or more records will show the same string in the email address, which means it becomes difficult to identify the actual email address associated with the review for attackers.

I have set  $k = 2$ , and treated review as sensitive information. This is the output:

| Email Address                    | Review      |
|----------------------------------|-------------|
| <a href="#">*16*@iiitd.ac.in</a> | lorem ipsum |
| <a href="#">*@gmail.com</a>      | lorem ipsum |
| <a href="#">*@gmail.com</a>      | lorem ipsum |
| <a href="#">*16*@iiitd.ac.in</a> | lorem ipsum |
| <a href="#">*123@yahoo.com</a>   | lorem ipsum |
| <a href="#">*123@yahoo.com</a>   | lorem ipsum |
| <a href="#">*123@yahoo.com</a>   | lorem ipsum |
| <a href="#">*16*@iiitd.ac.in</a> | lorem ipsum |

Q2)

a) The main issue with IPv4 is the limited amount of address space. IPv4 has an address space of  $2^{32}$ , around 4.3 billion, which is quickly being used up as the amount of computers increase. Now, IPv6 has an address space of  $2^{128}$ , around  $3.4 \times 10^{38}$ , which will take at least decades to deplete.

NAT (Network Address Translation) and Classless Internet Domain Routing (CIDR) have greatly increased the IPv4 address space to support many more devices without the need to upgrade or replace them. This meant that for enterprises, transitioning to IPv6 does

not offer many clear advantages in the short run, and the cost to transition is high. This has delayed the wider adoption of IPv6 addressing scheme.

In a design sense, yes, IPv6 is more secure than IPv4. IPv6 has built-in encryption capabilities and package integrity checking (IPsec). There is one issue with it however; IPv6 is new. This leads to more experts being familiar with IPv4 and in a practical sense, IPv4 security practices are better known.

b) Internet Protocol Security (IPSec) is a secure network protocol suite that authenticates and encrypts packets of data to provide secure encrypted communication between two computers over an Internet Protocol (IP) network.

While not mandatory; **yes**, IPsec can be implemented over IPv4.

c) Packet flooding attack floods the server with packets to make it unavailable to legitimate traffic by consuming all available server resources.

We can take the following steps to protect the network, with limited overhead:

Increase the backlog queue. For this, we would need to increase the memory of the server. Increasing memory

is always cheaper than other mechanisms, and has the lowest overhead.

We can then recycle the oldest half-open TCP connections. We can overwrite them once the backlog queue has been filled.

The server can also create cookies. The server responds to connection requests with an ACK packet, and the client after receiving it sends back another request. A machine attempting to flood won't be sending another request, thus DDoS attacks would be prevented.

d) In this architecture, we want to set up a secure communication channel for each of the device. We do not know if these devices have had a chance to communicate with each other earlier, or if the network is secure.

So, for this, we can make use of Diffie-Helman Algorithm.

Diffie Helman Algorithm allows those who have never met before to safely create a shared key, even over an insecure channel that might be monitored.

As the users do not have to have communicated with each other before in Diffie Helman, this does not

involve an offline key exchange. Also, Diffie Helman can be run on the two nodes without requiring a third-party service.

e) I connected my laptop to my mobile's hotspot. This is the result I got on [whatismyip.com](https://whatismyip.com):

What Is My IP?

My Public IPv4 is: 157.37.163.242 

My Public IPv6 is: 2405:204:1129:88c6:292c:e140:ad9:b69a 

As we can see, I have obtained both an IPv4 and IPv6 address. This is called Dual Stack.

### Advantages of IPv4:

- Almost all of the internet traffic uses IPv4, while not every host supports IPv6. IPv4 guarantees compatibility until the entire internet moves to IPv6
- IPv4 is more mature and more optimised, since it has been in use for longer.
- IPv4 addresses are smaller and easier for people to read.

### Disadvantages of IPv4

- The address space of IPv4 is limited ( $2^{32} = \sim 4.3$  billion). This is quickly being depleted, and soon there will not be enough IPv4 addresses to be assigned to new devices.
- As IPv4 is very old, it has no built-in security measures that can effectively prevent present day security threats and attacks without implementation of additional security protocols like the IPsec by the ISP.
- As we are running out of unique public IPv4 addresses, measures like NAT (Network Address Translation) have to be introduced. This requires additional configuration for forwarding, firewall, etc.
- IPv4 networks have to be configured either manually, or using Dynamic Host Arrangement Convention (DHCP) which can be confusing.

### Advantages of IPv6

- IPv6 has an increased address space, which overcomes the address depletion issue with IPv4, and allows direct addressing.
- Eliminates the need for NAT, thus enabling end to end connectivity, which improves functioning of peer-to-peer networks and services like VoIP.



- IPv6 reduces the size of routing tables, which makes routing more efficient.
- IPv6 has built in security mechanisms like IPsec.

### Disadvantages of IPv6

- IPv6 addresses are difficult for people to read and remember.
- Many networks do not support IPv6 yet. And there is no communication capability between IPv4 and IPv6 hosts. Thus, practices like dual stack and tunnelling have to be implemented to ensure connectivity in the transition state between IPv4 and IPv6.
- Conversion to IPv6 is costly, and for a lot of enterprises, it has very minimal short-term returns.
- IPv6 is new, and thus literature on IPv6 is minimal. So, in a practical sense, security experts are more familiar with IPv4 and traditional practices on IPv4 will provide more security.

Q3)

a) **No**, this protocol is not secure. This protocol is susceptible to the replay attack. An attacker can intercept the message Alice is sending, and can send

out the same message himself. Now, Bob will send back the relevant information to the Attacker instead of Alice, resulting in a breach of private information.

b) I would design R to be an asymmetric algorithm. If R is a symmetric algorithm, then an attacker who intercepts the encrypted challenge can decrypt it, since he also has R. And by having the decrypted challenge and R itself, he can use the information anytime he wants. Asymmetric algorithms would prevent the knowledge of R and the encrypted challenge to derive the decrypted challenge. Additionally, R would be attached with a timestamp. This is because the attacker won't be able to replay the message that quickly.

c) Secure Sockets Layer (SSL) is a standard security technology for establishing an encrypted link between a server and a client. SSL ensures a migration to HTTPS. In HTTPS, the message data is asymmetrically encrypted, thus any attacker that intercepts the message cannot do anything with it. Additionally, the attacker cannot pretend to be the server. SSL installs certificates on the servers, and these certificates are issued by reputable CA's. Thus, if an attacker tries to forge their own certificate or use a fake certificate, the

web browser will either warn Alice, or will throw an Invalid Certificate error.

Also, the Message Authentication Code of TLS will prevent Replay Attacks.

So, **no**, it is not possible for attackers to launch successful MITM or spoofing attacks.

d) **Yes**, we can perform mutual authentication if only one party has a verified certificate. In SSL, the server needs to have a verified certificate, while no certificate is required on the client side.

In SSL uses asymmetric cryptography for secured communication. In asymmetric cryptography, while the key for decryption needs to be private, the key for encryption can be public. The client obtains the public key from the server, while the server keeps the private key secret. **Yes, it is secure**, because the encrypted message cannot be decrypted without the private key, which is kept a secret, and brute forcing would take decades.

Q4)

a) We have multiple transient users and several persistent protected resources.

Although both ACL and Capabilities can perform the functions required, **Capabilities** would be more efficient for storing and managing user's permissions.

In ACL, we have a list of users for each file, while Capabilities is more user oriented. Since we have multiple transient users, in ACL we would have to make changes on each file for a single user. Thus, by using capabilities, we would have to make lesser changes and is hence more effective.

b) **Yes**, it is possible for an unauthorised user/process to misuse privileges of Alice to write/read contents of file X. Carol can make use of a Trojan Horse to write to file X.

Carol owns File Y. Carol can write to File Y.

Bob can read File Y and the Trojan Horse Program on Bob can read the contents of File Y and write it to File Z.

Alice owns file Z and also has write permission to File X. The Trojan Horse Program can read the contents of File Z and write the same to File X.

Thus, Carol has written to File X without having write permissions or being the owner.

c) I can prevent such unauthorised access by using the Bell-LaPadula security model. This model is used for

enforcing access control over a set of users and resources, by using clearances for subjects and security labels for objects. This model has 3 rules:

- i. NO READ UP rule: In this a subject can only read files on the same layer or the layers below it
- ii. NO WRITE DOWN rule: In this a subject can only write on the same layer or the layers below it
- iii. NO READ WRITE UP DOWN rule: In this a subject can only read and write on the same layer

Using these rules, unauthorized access of files is prevented.

Q5)

a) The only way to be perfectly anonymous on the internet is to never use the internet. Otherwise, if you do use the internet, it is **not possible** to be completely anonymous on the internet.

As a consequence of the protocols used for internet communication, some details of your device's setup are communicated to your Internet service provider, and often to the site or service you are using. While you can try to obfuscate your IP Address, your browser will still transmit information about the browser's configuration to the website server.

Even if you are using Tor to hide your identity, through data mining, inference and machine learning, using language models, speaker identification, facial recognition, location correlation, activity modelling, etc, your identity can be triangulated.

Due to a lot of data on citizens being public, finding one piece of identifier can be used to piece together your entire identity.

b) TOR (The Onion Routing project) uses the technique of Onion Routing to provide anonymity for users. In an onion network, messages are encapsulated in layers of encryption. The encrypted data is transmitted through a series of network nodes called onion routers, each of which "peels" away a single layer, uncovering the data's next destination. When the final layer is decrypted, the message arrives at its destination. The sender remains anonymous because each intermediary knows only the location of the immediately preceding and following nodes.

c) Yes, anonymity in Tor can be compromised. While Tor provides protection against traffic analysis in the network core, it cannot protect against traffic analysis at the network edge. This has led to multiple

government agencies across the world to monitor TOR end nodes.

The vulnerabilities with TOR are that, while TOR itself is hard to exploit, the operational security of the web servers are quite lax, because they think TOR would protect them, hence exploiting them using classic web attacks is easier. By using my supreme hacking skills, I would inject malware in the web applications, that would reveal information about the servers to me. Using this information, I would figure out the physical location of the server. Putting on my Batman cape, I would sneak into the server farm, and install backdoors on to the servers, which would reveal to me a lot of sensitive information.

Additionally, I would use the Bitcoin architecture to send malformed messages. By manipulating the fail-safes against DoS attacks, I would spam these malformed messages, until the Bitcoin IP is banned for 24 hours. This would lead to the users connecting to TOR through their own IP Address instead of the IP Address provided by the Bitcoin, from which I could easily piece together their entire identity.

A zero-day exploit is an exploit discovered by an attacker before the vendor is aware of it. Since the

vendor is unaware, no patches for it have been developed.

For me to give a zero-day exploit, I would have to find the vulnerability in TOR myself, which is not possible within the 39 hours given in this exam.

And in the case I did manage to find a zero-day, I would rather publish a paper out of it, than just casually mention it on a midsem exam for 5 bonus marks.